Relatório Teórico Complementar - Clube Aurora (Nível 2 Mista)

Nome do Aluno(a): [Seu Nome Aqui]
Turma: DevSecOps 1746
Data: [Data de Entrega]

---

1. Análise de Ameaças (STRIDE & Tríade CIA)

Preencha a matriz de análise para os 4 achados teóricos do Nível 2 (Mista):

Achado	Componente / Arquivo	Categoria STRIDE	Pilar CIA Afetado	Impacto no Negócio do Clube Aurora
F3: SQL Injection	`app/db.py` (`search_clients`)			
F5: Ausência de Headers HTTP	`app/main.py` e `app/__init__.py`			
F6: Quebra de Menor Privilégio	`app/db.py` / `app/main.py`			
F7: IaC Permissiva (Docker Compose)	`docker-compose.yml`			

---

2. Decisão de Arquitetura & Governança (F6)

O Tio Armando solicitou que a nova gerente de atendimento, Carla, receba privilégios de **Admin geral** do sistema.
1. Analise o pedido sob a ótica de **Segregação de Funções (SoD)** e **Menor Privilégio**.
2. Qual modelo de controle de acesso (RBAC) você recomenda para o Clube Aurora (papéis, permissões por rota)?
3. Como você responderia ao Tio Armando para recusar o admin total e propor a solução adequada?

---

3. Observabilidade e Detecção de Intrusão

Caso uma conta de funcionário seja comprometida ou ocorram tentativas de força bruta na API:
1. Quais eventos mínimos devem ser registrados no log de auditoria (`audit_log`)?
2. Como a equipe de operações saberia que um ataque de SQL Injection ou login malicioso está ocorrendo em tempo hábil?